

Soc Internship Day 32

Kerberoasting

Kerberoasting is a post-compromise attack technique used against Windows environments that rely on Kerberos authentication. The goal is to obtain encrypted service ticket data for service accounts and attempt to recover weak passwords offline, where the attacker is not limited by account lockout policies.

How it works (high level)

Kerberos uses **Service Principal Names (SPNs)** to identify services (such as SQL Server, IIS, or other applications) running under domain accounts.

At a high level:

1. An authenticated user requests a Kerberos service ticket for a service associated with an SPN.
2. The domain controller issues the ticket.
3. Part of that ticket is encrypted using a key derived from the service account's password.
4. An attacker who has obtained the ticket can try password guesses offline until one correctly decrypts the ticket.

The attack does not require administrator privileges. Any authenticated domain user can normally request service tickets for services they are authorized to access.

Why it is effective

Kerberoasting is successful primarily when service accounts have:

- Weak or easily guessed passwords
- Passwords that have not been changed for long periods
- Traditional user-managed passwords instead of automatically managed credentials

Because the guessing happens offline, organizations cannot rely on account lockout policies to stop the attack.

Golden Ticket attack

A Golden Ticket attack is a serious attack against a Windows Active Directory environment in which an attacker forges Kerberos Ticket Granting Tickets (TGTs). With a forged TGT, the attacker can impersonate virtually any user, including domain administrators, and request access to network resources without needing that user's password.

How it works (high level)

In a Kerberos-based Active Directory domain:

1. A user normally authenticates to the domain controller.
2. The domain controller issues a Ticket Granting Ticket (TGT).
3. The TGT allows the user to request service tickets for network resources without re-entering their password.

A Golden Ticket attack occurs when an attacker obtains the secret key associated with the KRBTGT account, which is the special account used by the domain to sign and validate TGTs.

Using that key, an attacker can create fake but cryptographically valid TGTs that the domain accepts as legitimate.

Why it is dangerous

A forged TGT can allow an attacker to:

- Impersonate almost any domain user
- Request access to many domain resources
- Maintain long-term persistence in the environment
- Bypass normal authentication by presenting forged tickets

Because the tickets appear valid, they can be difficult to distinguish from legitimate authentication without careful monitoring.

Requirements for the attack

A Golden Ticket attack generally requires an attacker to first gain very high privileges, such as Domain Administrator, and obtain the KRBTGT account's secret key (or password-derived key). This means it is typically a post-compromise technique used after an attacker has already significantly breached the environment.

DCSync attack

A DCSync attack is a post-compromise technique in Windows Active Directory where an attacker impersonates a domain controller to request password data from a real domain controller using legitimate replication mechanisms. Instead of compromising a domain controller directly, the attacker abuses the directory replication process to retrieve sensitive credential information.

How it works (high level)

Active Directory domain controllers regularly replicate directory data, including password-related information, to stay synchronized.

In a DCSync attack:

1. An attacker gains an account with directory replication privileges.
2. The attacker sends replication requests to a domain controller.
3. The domain controller treats the requests as legitimate replication traffic.
4. The attacker receives password-related data for requested accounts.

This attack uses standard Active Directory replication protocols rather than exploiting a software vulnerability.

Why it is dangerous

A successful DCSync attack can allow an attacker to obtain credential material for highly privileged accounts, including:

- Domain Administrator accounts

- Service accounts
- The KRBTGT account

Compromise of the KRBTGT account can enable further attacks, such as Golden Ticket attacks.

LDAP (Lightweight Directory Access Protocol)

LDAP (Lightweight Directory Access Protocol) abuse refers to the misuse of Active Directory queries to gather information, identify privileged accounts, or prepare for further attacks. Because LDAP is used for normal administrative operations, distinguishing legitimate activity from abuse requires looking for unusual patterns rather than a single event.

Common LDAP abuse indicators

1. Excessive directory enumeration

An account performs an unusually large number of LDAP queries in a short period.

Potential indicators:

- Thousands of LDAP search requests
- Rapid queries across many Organizational Units (OUs)
- Enumeration of nearly all directory objects

2. Enumeration of privileged accounts

Repeated searches targeting:

- Domain Admins
- Enterprise Admins
- Administrators
- Backup Operators
- Service accounts
- Accounts with delegated privileges

3. Service account discovery

LDAP queries requesting:

- Service Principal Names (SPNs)
- Service accounts
- Computer accounts running services

4. Trust relationship enumeration

Queries related to:

- Domain trusts
- Forest trusts
- Cross-domain relationships

5. Group membership enumeration

Repeated requests for:

- Nested groups
- Administrative groups
- Privileged security groups

6. Computer and server enumeration

Large-scale discovery of:

- Domain controllers
- File servers
- SQL servers
- Exchange servers
- Certificate services
- Workstations

7. User account harvesting

Queries collecting:

- Usernames
- Email addresses
- Department information
- Phone numbers
- Manager relationships

8. Unusual LDAP clients

LDAP requests originating from:

- Workstations that rarely perform administrative tasks
- Unknown hosts
- Non-Windows systems
- Unexpected applications

9. Anonymous or unexpected LDAP binds

Watch for:

- Anonymous bind attempts (where enabled)
- Failed bind attempts
- Authentication using unusual service accounts

10. Off-hours LDAP activity

Significant LDAP searches occurring:

- Overnight
- Weekends
- Outside normal administrative windows

privilege escalation

Vertical privilege escalation

A user or process gains higher privileges than originally assigned.

Examples include:

- Standard user → Local Administrator
- Help desk account → Domain Administrator
- Application account → Root/Administrator

Horizontal privilege escalation

An attacker gains access to another account with similar privilege levels.

Examples include:

- User A accessing User B's data
- One service account impersonating another
- Session hijacking between users

Common privilege escalation methods

1. Credential theft

Attackers attempt to obtain credentials through methods such as:

- Password guessing or spraying
- Phishing
- Credential reuse
- Theft of stored credentials
- Token or session theft

Defenses

- Multi-factor authentication (MFA)
- Password managers
- Strong password policies
- Credential Guard (Windows)

2. Misconfigured permissions

Examples include:

- Overly permissive file or directory ACLs
- Excessive Active Directory permissions
- Weak cloud IAM policies
- Writable service configurations

Defenses

- Principle of least privilege
 - Regular permission reviews
 - Automated configuration auditing
-

3. Software vulnerabilities

Attackers may exploit unpatched vulnerabilities that allow elevation of privilege in:

- Operating systems
- Device drivers
- Applications
- Hypervisors
- Containers

Defenses

- Prompt patch management
- Vulnerability scanning
- Exploit mitigation features

4. Service and scheduled task misconfigurations

Examples include:

- Services running with excessive privileges
- Incorrect permissions on service executables
- Insecure scheduled task configurations

Defenses

- Review service permissions
- Restrict write access to executables
- Use dedicated service accounts with minimal privilege

5. Active Directory misconfigurations

Examples include:

- Excessive delegation
- Misconfigured group memberships
- Over-privileged service accounts
- Inappropriate replication permissions

Defenses

- Audit privileged groups
- Implement tiered administration
- Monitor privileged account activity

6. Cloud identity and IAM issues

Examples include:

- Overly broad IAM roles
- Unnecessary API permissions
- Misconfigured trust relationships

Defenses

- Least-privilege IAM policies
- Just-in-time privileged access
- Continuous permission reviews

7. Application authorization flaws

Examples include:

- Missing authorization checks
- Insecure direct object references (IDOR)
- Broken access control

Defenses

- Enforce server-side authorization
- Security testing
- Code reviews